YAML Deserialization RCE Vulnerability Report

Expert track, redacted for publication. Vulnerability analysis, exploitation methodology and remediation.

1. Executive Summary

This vulnerability exists in a task scheduler that accepts YAML configuration files. The YAML parser uses unsafe deserialization, allowing arbitrary code execution when processing maliciously crafted YAML.

2. Vulnerability Description

The YAML parser resolves arbitrary Python object tags during deserialization, which allows an attacker to instantiate arbitrary system classes and execute commands on the server.

3. Exploitation Methodology

1. Identify that the scheduler accepts YAML configuration input.
2. Craft a malicious YAML payload that uses unsafe deserialization tags to execute system commands.
3. Submit the malicious YAML configuration. The parser deserializes the payload and executes the embedded commands.

4. Impact

This allows remote attackers to execute arbitrary code on the server, leading to full system compromise.

5. Remediation Recommendations

Use a safe YAML parser configuration that only resolves basic data types, and disables arbitrary object deserialization tags. Validate all incoming YAML against a strict schema before parsing.